Third-Party Security Assessment Procedure

Document ID	SEC-011
Department	IT and Information Security
Document type	Procedure
Owner	GRC Manager
Version	3.2
Status	APPROVED
Effective / last reviewed	2026-01-11
Audience	All employees and contractors
Related documents	OPS-003, OPS-004, SEC-014

Summary. Procedure for assessing the security of third-party vendors before and during their relationship with Northstar Systems, covering risk tiers, questionnaires, assurance reports, assessment timelines, Data Processing Agreements, reassessment frequency and exceptions.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This procedure explains how Northstar Systems Private Limited assesses the security and privacy risk of third parties before they receive access to company systems or data, and how that risk is monitored during the relationship. It makes sure that vendors who handle Confidential or Restricted data, or who support critical systems, meet an acceptable security standard before a purchase order (PO) is issued.

The procedure applies to every vendor, supplier, contractor firm, SaaS provider, consultant, cloud or hosting provider, and any subprocessor used for the Northstar Nexus Platform, Nexus Connect or Nexus Insight. It covers new vendors, renewals, material changes in scope and ad hoc reassessment after an incident. It is operated by the GRC team in IT/Security together with the Procurement Desk and the requesting business owner. Vendor onboarding, purchasing approvals and contract rules are in OPS-003 and OPS-004, and incident handling for vendor breaches follows SEC-010. Audit logging requirements are in SEC-014.

Any legal or regulatory reference in this document is illustrative and must be verified by Legal before external use.

2. Definitions

- **Third party or vendor**: any external organisation or individual that supplies goods or services to Northstar or processes Northstar or customer data.
- **Business owner**: the Northstar employee who requested the vendor and is accountable for the relationship.
- **Security questionnaire**: the standard set of questions about governance, access control, encryption, incident response, business continuity and privacy that the vendor completes.
- **Independent assurance report**: an external attestation of controls, for example a SOC 2 Type II report or an ISO 27001 certificate (illustrative).

- **DPA**: Data Processing Agreement, the contract that sets how a vendor may process personal data on Northstar's behalf.
- **Risk tier**: Critical, High, Moderate or Low, assigned by data access and system criticality.
- **Residual risk**: the risk left after controls and vendor commitments are considered.
- **NorthBuy**: the procurement system with vendor master, purchase requisitions and contracts repository.

3. Roles and Responsibilities

Role	Responsibility
Business owner	Starts the assessment early, describes data and access accurately, owns the relationship
Procurement	Collects vendor documents, performs onboarding in NorthBuy, blocks PO until clearance
GRC Manager	Owns this procedure, assigns tiers, reviews evidence, records residual risk
Security Engineering	Reviews technical controls and integration design
Privacy Officer	Reviews DPAs and personal data handling
Legal	Reviews contracts, liability and security clauses
CISO delegate	Approves risk acceptance and exceptions
Finance	Releases payment only after onboarding is complete

4. Risk Tiering

The GRC team assigns a tier at the start of every assessment using the information given in the NorthBuy vendor request. If a vendor fits more than one tier, the highest tier applies.

Tier	Typical criteria	Examples
Critical	Hosts or processes customer production data, holds privileged access to production, or whose failure stops customer platform operations	Cloud or hosting provider, managed security provider, payment processor
High	Processes Confidential or Restricted data, including employee personal data, or integrates into production systems	Payroll bureau, background verification firm, customer support outsourcer
Moderate	Handles Internal data or has limited access to corporate systems	Marketing tools, recruitment platforms, training providers
Low	No access to systems or Northstar data	Stationery supplier, catering, courier

The tier is reviewed whenever the scope changes. A vendor that adds access to Restricted data is reassessed under the higher tier before the change goes live.

5. Assessment Requirements by Tier

Requirement	Critical	High	Moderate	Low
Security questionnaire	Yes, full	Yes, full	Short form	No
Independent assurance report (SOC 2 Type II or ISO 27001, illustrative)	Required before PO	Required before PO	Recommended	No

Requirement	Critical	High	Moderate	Low
Data Processing Agreement when personal data is shared	Required	Required	Required if any personal data	Not appl icable
Technical review by Security Engineering	Yes	If integrated	No	No
Reassessment frequency	Annual	Every 2 years	At renewal	None
Right-to-audit and breach notice clause	Required	Required	Standard terms	Standar d terms

For Critical and High vendors, a questionnaire plus an independent assurance report must be completed before a PO is issued. A Data Processing Agreement must be signed before any personal data is shared, even for a pilot or trial.

Vendors that access Confidential or Restricted data must also submit the security questionnaire as part of the vendor document set, in addition to the standard documents: PAN, GSTIN, cancelled cheque or bank proof, NDA and a conflict-of-interest declaration.

6. Procedure

6.1 Step 1: Raise the request

The business owner submits a vendor request in NorthBuy and states the service, expected spend, data types, systems accessed, locations of processing, and any integration with the Northstar Nexus Platform. The request must be made before any commitment. No PO, contract signature, trial with real data or access grant may happen before clearance.

6.2 Step 2: Document collection and tiering

Procurement collects the vendor document set. The GRC Manager assigns the risk tier within 2 business days of the request. Procurement completes onboarding in the NorthBuy vendor master within 5 business days of a complete document set.

6.3 Step 3: Questionnaire and evidence

GRC sends the questionnaire. The vendor should reply within 10 business days; if not, the request is paused and the business owner is told. When the questionnaire is complete, the assessment SLA is 10 business days from the date of a complete questionnaire, including review of assurance reports.

The assessor checks:

1 Governance: security policies, named security lead, staff screening and training.
2 Access control: MFA, least privilege, joiner and leaver handling, privileged access.
3 Data protection: encryption at rest and in transit in line with SEC-008, data location, retention and deletion.
4 Vulnerability management: patching, scanning, penetration testing.
5 Incident response: notification commitments, contacts and past incidents.
6 Business continuity: backups, recovery objectives and tested plans.
7 Subprocessors: who else touches the data and where.
8 Privacy: lawful basis, DPA readiness and support for access and erasure requests.

6.4 Step 4: Findings and remediation

Findings are rated High, Medium or Low. Any High finding must be fixed or covered by a compensating control before clearance. The vendor agrees a remediation plan with dates, and the GRC team tracks it in NorthDesk. Medium findings need a plan within 30 days. Low findings are noted.

6.5 Step 5: Decision

The GRC Manager records one of the following outcomes:

- **Approved**: no unresolved High findings.
- **Approved with conditions**: remediation dates and contract clauses agreed; the business owner accepts the follow-up.
- **Rejected**: risk not acceptable; Procurement tells the vendor.

For Critical vendors with unresolved findings, the CISO delegate must approve residual risk in writing. Risk acceptance expires after a maximum of 90 days, then the item is reviewed again.

6.6 Step 6: Contract and onboarding

Legal and Procurement make sure that the contract includes security clauses: confidentiality, security controls, breach notification within an agreed timeframe, right to audit, subprocessor approval, return or deletion of data, and cooperation in incidents. A DPA is attached when personal data is processed. Contracts follow the Delegation of Authority; Legal review is required for contracts above INR 5,00,000, any multi-year term or non-standard terms, and auto-renewal clauses need General Counsel approval. The PO is issued only after the assessment is cleared and the vendor is in the NorthBuy vendor master.

6.7 Step 7: Access provisioning

Vendor staff access is granted through the NorthDesk Access Request form with least privilege, MFA through NorthID or an approved equivalent, and an expiry matching the contract. Vendors connect through NorthTunnel vendor profiles as described in SEC-009 and never use shared accounts. Access is reviewed in the quarterly user access reviews.

7. Reassessment and Monitoring

- Critical vendors are reassessed every year, High vendors every 2 years, and Moderate vendors at renewal.
- NorthBuy sends a renewal alert 90 days before contract expiry; the GRC team checks that the assessment remains valid before renewal.
- A new assessment is triggered by a vendor breach, a major change in services or ownership, a lapse in certification, adverse news, or a failed audit.
- Vendors must notify Northstar of security incidents affecting Northstar data within the timeframe set in the contract, normally within 72 hours of discovery, so that Northstar can meet its own customer notification deadline.
- The GRC team keeps a vendor risk register with tier, last assessment date, open findings and next review date, and reports the status to the CISO quarterly.

8. Offboarding

When a vendor relationship ends, the business owner starts offboarding in NorthBuy. Vendor accounts are disabled by the last day of service, and any dormant vendor account is disabled after 60 days of inactivity and deleted after 180 days. The vendor must return or delete Northstar data

and give a written certificate of deletion within 30 days, or the retention period required by law or contract. Keys, tokens and secrets shared with the vendor must be rotated immediately.

9. Worked Examples

Example 1: The HR team wants to use an outsourced background verification firm. The firm will receive candidate identity documents, which is employee personal data. GRC rates the firm High. The firm completes the questionnaire and provides an ISO 27001 certificate (illustrative). A DPA is signed before any candidate data is shared. The assessment is completed in 8 business days after the questionnaire was complete, inside the 10 business day SLA. The PO value is INR 3,50,000, so Legal reviews the contract as well.

Example 2: Marketing plans to buy a webinar tool for INR 40,000 a year. The tool holds the names and business emails of prospects but no customer production data. GRC rates it Moderate, uses the short questionnaire and a DPA for the personal data. A SOC 2 report is recommended but not required. The DoA approver for the purchase is the department head.

Example 3: An engineering team wants to try an AI code assistant that sends source code to the vendor. If the tool is not on the Approved AI Tools list, the request goes through this procedure. Since source code is Confidential, the vendor is rated High, and the business owner must wait for clearance before using it with any real code.

Example 4: A managed security provider is being onboarded to monitor NorthWatch alerts. The provider will have privileged access to logs that may contain personal data and so is Critical. The questionnaire, a SOC 2 Type II report, a Security Engineering technical review, a DPA and a right-to-audit clause are all required before the PO. The CISO delegate approves residual risk for one open Medium finding with a 90-day remediation date. The vendor is reassessed annually.

10. Special Cases

Cloud and subprocessor chains

Many Northstar vendors rely on other providers. For Critical and High vendors the questionnaire asks for a list of subprocessors, their locations and the data they touch. Northstar must be told before the vendor adds or changes a subprocessor that handles Northstar or customer data, and Northstar may object within 30 days. Where a vendor stores data outside India, the Privacy Officer and Legal decide whether the transfer is acceptable (illustrative; to be verified by Legal before external use).

Existing vendors discovered without assessment

Sometimes a team has used a tool for months without going through this procedure (shadow IT). The GRC team assigns a tier, runs the assessment as normal and, for Critical or High tiers, may suspend use of the tool until clearance. The business owner explains why the procedure was skipped. Repeated bypass is reported to the department head and may be treated as a breach of SEC-006.

Open source and free tools

Free or open source tools that run only on Northstar systems and process no external data are reviewed through the engineering open source process rather than as vendors. Free hosted services that receive company data are treated as vendors and assessed in the same way as paid

ones, with the tier set by the data involved.

Customer-mandated subprocessors

If a customer contract requires Northstar to use or avoid a particular provider, the Customer Success Manager informs GRC, and the vendor is assessed under the normal tier. The customer's requirements are recorded in the vendor risk register so that renewals do not overlook them.

Assessment evidence and metrics

All questionnaires, reports, decisions and approvals are stored in the NorthBuy contracts repository against the vendor record and retained for the life of the contract plus the retention period for customer contracts, which is 8 years after expiry. GRC reports the following measures each quarter: number of assessments by tier, average days to complete, percentage of Critical and High vendors with current assessments, open High findings, and exceptions granted. A target of 100 percent current assessments for Critical vendors applies.

11. Exceptions and Escalation

An exception, such as urgent use of a vendor before assessment is complete, must be requested in NorthDesk with a business case, the data involved and compensating controls such as using only synthetic data. The business owner's department head and the CISO delegate must both approve. The exception may last at most 90 days and cannot be used to give a vendor Restricted data, production access or personal data without a DPA. Disputes about tier or findings go to the CISO. Payment to a vendor that bypassed this procedure is held by Finance, because invoices without a PO are not paid.

Splitting a purchase or contract to avoid assessment thresholds is prohibited and is treated as a policy breach.

12. Frequently Asked Questions

- **How long does an assessment take?** The SLA is 10 business days from a complete questionnaire. Vendor delays in answering do not count against it.
- **Which vendors need an assurance report?** Critical and High vendors need one before a PO.
- **How often are Critical vendors reassessed?** Every year; High vendors every 2 years.
- **Can we share personal data during a trial?** Not before a DPA is signed.
- **Who accepts risk if a vendor has open findings?** The CISO delegate, for a maximum of 90 days at a time.

13. Related Documents

See OPS-003, OPS-004, SEC-014, SEC-009 for vendor connectivity, SEC-010 for vendor incidents and SEC-006 for AI tools.

14. Revision History

Version	Date	Change
3.0	2025-03-03	Four-tier model and 10 business day SLA introduced
3.2	2026-01-11	Added offboarding section and AI vendor example